

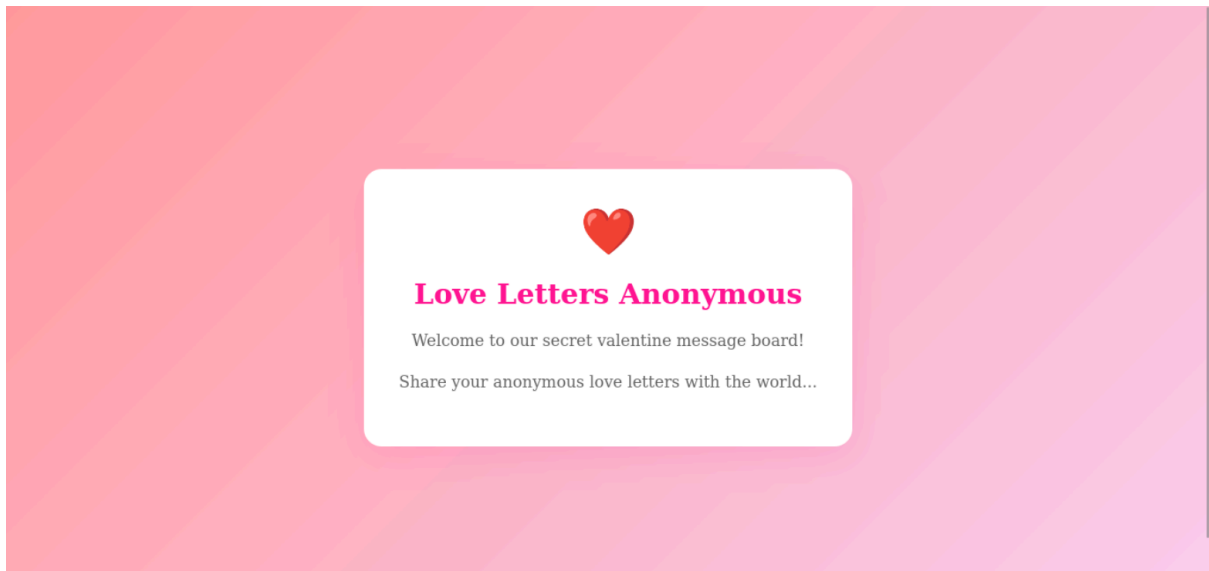
Hidden Deep Into my Heart

CTF - TryHackMe

Caio Godoy Araújo

The first step was accessing the target URL.

The page only showed a simple Valentine's Day themed message board with no visible functionality



After inspecting the page source, nothing suspicious was found.

Next, directory enumeration was performed using Gobuster to search for hidden paths.

During this process, the file robots.txt was discovered.

The file contained the following content:

User-agent: *

Disallow: /cupids_secret_vault/*

cupid_arrow_2026!!!

This revealed two important pieces of information:

- A hidden directory: /cupids_secret_vault
- A suspicious comment that appears to contain a password: cupid_arrow_2026!!!

Normally, the robots.txt file is used to instruct search engine crawlers which pages should not be indexed. However, it is publicly accessible and should never contain sensitive information.

By navigating to:

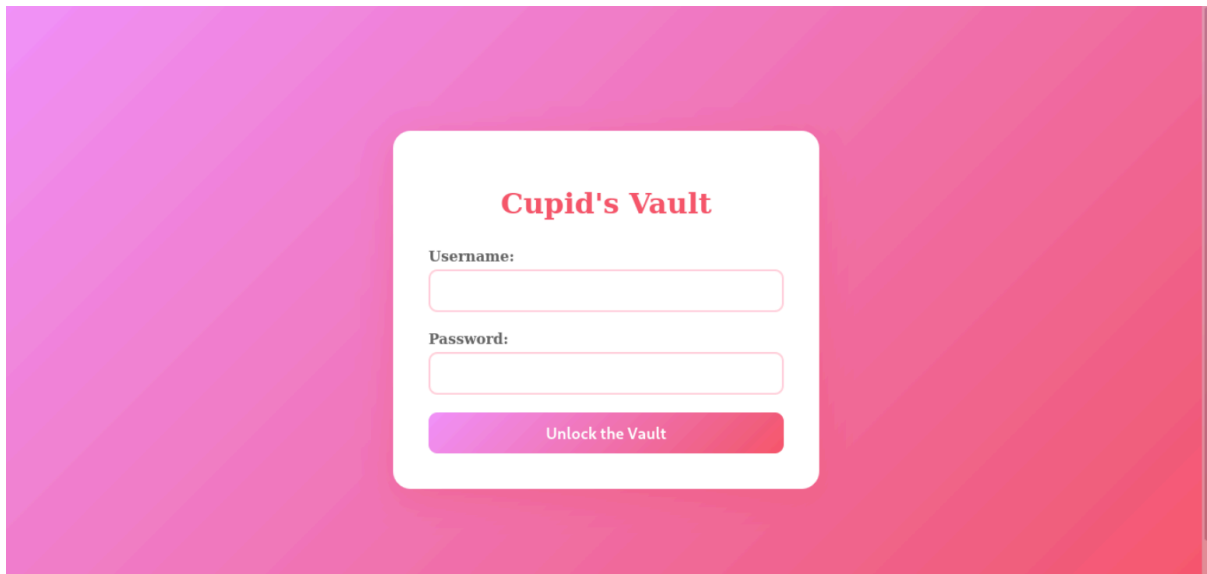
/cupids_secret_vault

a message appeared indicating that further discovery was required.

Running Gobuster again inside this directory revealed another hidden page:

/administrator

This page contained a login panel.



Based on the clues discovered earlier:

- The comment inside robots.txt suggested a password.
- This the Cupid's Vault, Cupid MUST be the admin.

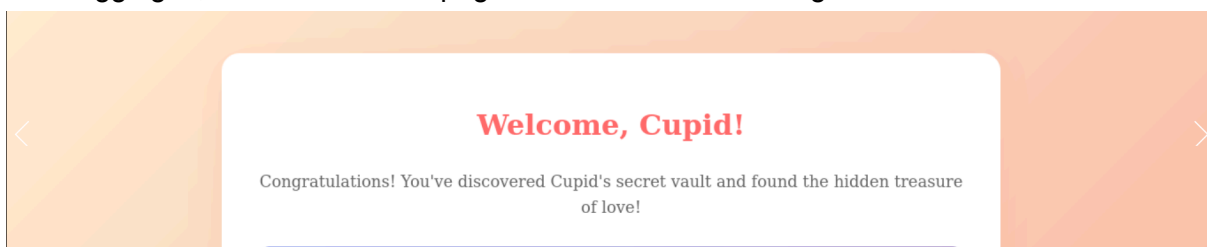
Testing the following credentials:

Username: admin

Password: cupid_arrow_2026!!!

Successfully authenticated into the administrator panel.

After logging in, the administrator page revealed the hidden flag.



This lab demonstrates several common security misconfigurations:

Sensitive Information Disclosure

A password was exposed inside a public file (robots.txt) as a comment.

```
# cupid_arrow_2026!!!
```

Sensitive credentials should never be stored in publicly accessible files.

Exposure of Hidden Administrative Paths

The robots.txt file revealed a restricted directory:

/cupids_secret_vault

Attackers frequently inspect robots.txt to discover hidden endpoints.

Weak / Predictable Username

The username admin was easily guessable due to the theme of the application. Using thematic or predictable usernames increases the risk of compromise.

Lack of Access Control

The administrator panel was accessible directly via URL:

/administrator

Without proper protections such as:

- strong authentication
- rate limiting
- access restrictions